

Reporte ejecutivo de riesgos

Clínica privada — Registro inicial en SimpleRisk

Dirigido al Directorio | 5 de septiembre de 2026 | Escenario ficticio

Resumen ejecutivo

La auditoría externa motivó la construcción de un registro inicial de riesgos para una clínica de 120 empleados que atiende aproximadamente 800 pacientes diarios y depende de historias clínicas digitales, datos de obras sociales y facturación.

El análisis identificó una exposición elevada: nueve de los diez riesgos evaluados requieren tratamiento prioritario o inmediato. La concentración de riesgos críticos en ransomware, accesos indebidos y phishing indica que la continuidad asistencial y la protección de datos sensibles dependen de fortalecer simultáneamente identidades, tecnología, procesos y capacidad de recuperación. Los controles actuales se consideran parciales y aún no existe evidencia de su eficacia sostenida. El riesgo restante, R09, corresponde a fallas físicas o ambientales y se mantiene en nivel medio bajo monitoreo.

10

riesgos evaluados

3

críticos

6

altos

3

planes definidos

Decisión requerida. Autorizar el inicio de los tres planes de acción ya definidos y exigir planes inmediatos adicionales para los riesgos críticos R01, R02 y R04. El costo inicial estimado de la cartera planificada es de USD 27.500.

Top 5 riesgos por nivel

ID	Riesgo	P × I	Nivel	Consecuencia principal
R01	Ransomware sobre historias clínicas y sistemas de atención	4 × 5 = 20	Crítico	Paralización operativa, pérdida o exposición masiva de información.
R02	Acceso indebido a historias clínicas	4 × 4 = 16	Crítico	Vulneración de datos sensibles, consecuencias legales y pérdida de confianza.
R04	Robo de credenciales mediante phishing	4 × 4 = 16	Crítico	Acceso inicial para fraude, filtración o propagación de ataques.
R03	Alteración de información clínica	3 × 5 = 15	Alto	Decisiones asistenciales basadas en datos incorrectos y pérdida de trazabilidad.
R07	Imposibilidad de recuperar respaldos	3 × 5 = 15	Alto	Conversión de un incidente temporal en pérdida prolongada o permanente.

Los empates se ordenaron priorizando la posible afectación de la atención y la continuidad de los servicios esenciales. La clasificación sigue la matriz de la cátedra: crítico 16–25, alto 10–15, medio 5–9, bajo 1–4.

Estado de los planes de acción

Los tres planes se encuentran en estado **Mitigation Planned**, con 0% de avance. SimpleRisk mantiene por ahora el riesgo residual igual al inherente: la reducción solo podrá reconocerse una vez implementados y verificados los controles.

PA01 — Respaldos 3-2-1 y restauración0% de avance

Copia aislada o inmutable, separación de credenciales y pruebas trimestrales. Primera prioridad porque reduce R07 y mejora la recuperación frente a R01.

Responsable: Frank Castle — Infraestructura y TI | Vencimiento: 31/10/2026 | Presupuesto: USD 8.000 |

Riesgo asociado: R07

PA03 — Continuidad con obras sociales0% de avance

Segundo enlace de conectividad, conmutación automática, reintentos y SLA. Protege admisión y facturación; requiere coordinación con proveedores.

Responsable: Constanza Romero — Administración y Finanzas | Vencimiento: 15/11/2026 | Presupuesto: USD 7.500 |

Riesgo asociado: R08

PA02 — Integridad de historias clínicas0% de avance

Trazabilidad, versionado y protección de cambios clínicos. Dirección Médica define los campos críticos; TI implementa los controles.

Responsable: Juliana Gattas — Dirección Médica | Vencimiento: 15/12/2026 | Presupuesto: USD 12.000 |

Riesgo asociado: R03

Inversión inicial estimada de la cartera: **USD 27.500**

Hitos y criterios de aceptación

	Primer hito	Criterio de cierre verificable
PA01	Inventario de sistemas, RTO/RPO y arquitectura de respaldo aprobados.	Restauración integral trimestral dentro del tiempo objetivo, con evidencia y acciones correctivas.
PA03	Segundo proveedor y cláusulas de disponibilidad seleccionados.	Prueba semestral de conmutación y recuperación de operaciones pendientes sin pérdida de registros.
PA02	Campos clínicos críticos y eventos auditables definidos por Dirección Médica.	Registro protegido de usuario, fecha, valor anterior/nuevo, e historial consultable de modificaciones.

Gobernanza y seguimiento

- Presentar avance mensual al Comité de Dirección; escalar desvíos de fecha o presupuesto.
- El responsable de cada plan rinde cuentas por su ejecución; TI y Seguridad aportan evidencia técnica.
- Auditoría debe validar la eficacia de los controles antes de reducir el riesgo residual o declarar un plan completado.
- R01, R02 y R04 siguen sin un plan formal específico y requieren patrocinio inmediato del Directorio.

|

Decisión requerida. Confirmar responsables, autorizar la ejecución de la cartera planificada y solicitar en un plazo de 30 días planes específicos para los tres riesgos críticos restantes.

Recomendaciones prioritarias

- 1. Tratar inmediatamente los riesgos críticos.** Autorizar EDR, segmentación de red, MFA generalizado, revisión trimestral de privilegios, monitoreo de accesos y un programa continuo de concientización. El plan de respaldos mejora la recuperación, pero no reemplaza las medidas preventivas necesarias para R01, R02 y R04.
- 2. Ejecutar y controlar los tres planes ya definidos.** Mantener responsables, fechas y presupuesto; medir avances mensualmente y exigir evidencia de restauración, conmutación y trazabilidad antes de reducir el riesgo residual.
- 3. Implementar una estrategia de defensa en profundidad.** Superponer capas de control independientes: (i) identidad y autenticación multifactor; (ii) protección de endpoints, correo y red con monitoreo activo; y (iii) respaldos inmutables probados, continuidad operativa y un procedimiento de respuesta a incidentes. Si una capa falla, las restantes deben contener el daño.
- 4. Reforzar la protección frente a amenazas externas y suplantación.** El phishing que imita a una obra social o proveedor explota la confianza del personal para obtener credenciales o un punto de acceso inicial. Se recomienda MFA generalizado, validación por canal alternativo ante solicitudes sensibles, filtrado de correo y capacitación práctica basada en simulacros periódicos.
- 5. Proteger la infraestructura física y su ubicación.** La sala técnica debe estar separada de fuentes de riesgo ambiental (calor, agua, incendio) e incorporar sensores ambientales, detección de humo y filtraciones, UPS y generador probados periódicamente, y control de acceso físico.

Hoja de ruta para decisión del Directorio

0–30 días	Aprobar presupuesto y responsables; formalizar planes para R01, R02 y R04; activar MFA y revisión urgente de privilegios; definir RTO/RPO.
31–60 días	Implementar copia aislada/inmutable, segundo enlace de conectividad y primeras mejoras de auditoría clínica; ejecutar simulación de phishing y prueba de conmutación.
61–90 días	Probar restauración integral, verificar logs y versionado, revisar proveedores y reevaluar probabilidad, impacto y riesgo residual en SimpleRisk.

Decisión requerida. El Directorio debe tratar la ciberseguridad como un riesgo asistencial y de negocio. La prioridad no es solo adquirir tecnología, sino demostrar que los controles funcionan mediante pruebas, métricas y revisión independiente.

Fuentes de referencia: Ley 25.326 de Protección de los Datos Personales; Ley 26.529 de Derechos del Paciente e Historia Clínica; CISA, *StopRansomware Guide*; HHS, *Health Industry Cybersecurity Practices*; NIST SP 800-53 Rev. 5 y NIST SP 800-34. Evaluación basada en la matriz de probabilidad por impacto proporcionada por la cátedra. Todos los datos personales y organizacionales utilizados son ficticios.